

研究計畫

基於機器學習之動態 Web 攻擊偵測與可解 釋自動化防禦系統

摘要

隨著網路應用程式的普及，SQL Injection、跨網站指令碼（XSS）以及參數篡改等網路攻擊不斷演化。現有的 Web Application Firewall (WAF) 雖然能透過靜態規則有效攔截已知攻擊，但對於未知的攻擊樣態有時未能適應。攻擊者往往利用尚未被記錄的手法在短時間內來繞過傳統防禦。

本研究旨在提出一套 AI 輔助的攻擊偵測機制，將使用者請求的語意特徵與行為模式納入分析，補足 WAF 規則的不足。此方法不僅能提升對未知攻擊的偵測能力，也能在降低誤判率的同時，提高整體系統的防禦效能。同時系統會提供可解釋的判斷說明（例如關鍵字/特徵）、自動化的規則建議以供人員審核，並在審核通過後自動更新規則庫與增量訓練模型，確保防護能隨攻擊演進持續更新與改善。

研究動機與研究問題

根據 Bilic et al. (2024) 顯示，WAF 雖能有效防護已知的 SQL Injection、XSS 等攻擊，但仍存在一些不足。首先，WAF 需要攔截並分析所有 HTTP 請求與回應，有時可能誤攔合法流量，影響使用者體驗。此外，傳統 WAF 雖依靠規則能防禦已知攻擊，但面對混淆、編碼、分片、加密、或零日攻擊等手法時，仍可能被繞過。最後，WAF 的部署與維護成本高，需要人力持續監控與調校，才能因應應用程式更新與不斷變化的安全需求。

基於上述現況，本研究將探討以下問題：一、如何利用 AI 模型強化 WAF 對未知與變形攻擊的偵測能力，以提升整體防護效果；二、如何在提高準確率的同時，降低誤判率，避免影響合法使用者的操作體驗；三、如何將 AI 模型與現有

WAF 結合，使系統能即時分析使用者請求，自動提供規則更新建議，並透過增量學習持續調整模型，補足傳統 WAF 在效能與管理上的不足。本研究希望引入 AI 輔助的攻擊偵測與分析，將使用者請求的內容特徵與行為模式納入評估，不僅可提升對未知攻擊的偵測能力，也能降低誤判率，同時減少人工調整規則的負擔，進而建構一套能隨攻擊演進自我學習、即時防護且減少人工維護負擔的智慧化 Web 防護系統。

文獻探討與回顧

根據本研究議題，以下將針對 AI 強化 WAF 偵測、HTTP 行為特徵分析、輕量增量學習與 Human-in-the-Loop，以及可解釋人工智慧（XAI）進行探討。

一、AI 強化 WAF 偵測未知與變形攻擊

Bakır (2024)提出利用機器學習分類器結合 Word2Vec、Universal Sentence Encoder (USE) 和 FastText 等特徵提取方法，實現對 SQL 注入和 XSS 攻擊的統一檢測。實驗結果顯示模型在未知攻擊上的準確率明顯優於傳統規則。因此本研究計畫導入此技術來補足 WAF 的防護不足。

二、HTTP 行為特徵分析

除了 payload 特徵，HTTP 請求中的行為特徵（如 headers、URL、請求頻率）也對辨識攻擊具有顯著幫助。Zhao et al. (2023)提出了一種多特徵融合方法，透過結合多個輕量級分類器分析不同來源的特徵，成功提升了對 Web 掃描行為的辨識能力。本研究計畫將參考此方法，將 payload 與行為特徵輸入多種特徵模型，以充分捕捉攻擊特徵並提升偵測效能。

三、輕量增量學習與 Human-in-the-Loop

Mishra and Diesner (2022) 中的 PyTAIL 系統，使用了將模型自動生成的高置信度偽標籤，顯示給使用者做決策及排序，而後進行小批量增量更新，避免全部重新訓練模型。本研究將同樣採用 PyTAIL 來實現輕量增量學習與 human-in-the-loop，確保模型能持續學習新型態攻擊。

四、可解釋人工智慧（XAI）與規則建議

為提升模型透明度及使用者信任，Cate and Aishat (2023) 中使用 XAI 產生可視化及特徵重要性分析，讓使用者能理解模型決策原因，並在生成 WAF 規則時提供參考。此外，也使用 SHAP 方法指出攻擊證據或關鍵行為特徵，支援使用者判斷。

在規則生成方面，對於明顯的攻擊特徵，如 SQLi 或 XSS 中的關鍵字、特殊符號，以及異常行為模式（請求頻率、Header 變化等），系統可自動生成簡單的 WAF 規則，例如關鍵字匹配、行為閾值限制，可以直接套用於 WAF，實現即時防護並降低人工負擔。對於較複雜或高度變形的攻擊，系統則依靠 XAI 分析輸出，標示對模型判斷最關鍵的文字或行為特徵，由管理者根據這些資訊自行判斷與設計精細規則，不僅能即時提供防護建議，也能降低誤判風險。

研究方法與步驟

研究方法

本研究將結合文字特徵與 HTTP 行為特徵，使用多種特徵模型進行訓練。文字特徵包括 payload 的 BOW、TF-IDF 或 Transformer embedding，行為特徵則包括請求頻率、Session 長度、Header 變化及錯誤率等統計與序列特徵。模型訓練將採用監督式學習進行預訓練，並搭配增量學習與 Human-in-the-Loop，以小批量方式更新模型並納入人工確認與高置信度偽標籤，以保持模型對新型態攻擊的適應性。可解釋人工智慧（XAI）技術將用於標示對模型判斷最關鍵的文字或行為特徵，並支援自動生成簡單 WAF 規則或供管理者參考設計規則。

研究步驟

步驟一、資料蒐集與標註

收集公開 SQLi/XSS 資料集並模擬 HTTP 請求行為（如 headers、URL、請求頻率、Session 長度及錯誤率），並分割為訓練、驗證與測試集。

步驟二、特徵工程與模型建構

對 payload 文字進行向量化，對 HTTP 行為提取統計與序列特徵，將文字與行為特徵輸入多個特徵模型，並對模型偵測不同特徵的表現進行評估。

步驟三、增量學習與 Human-in-the-Loop

利用 PyTAIL 系統將模型高置信度樣本提供給管理者驗證，將經人工確認的樣本與高置信偽標籤進行輕量增量更新，確保模型持續適應新型態攻擊。

步驟四、可解釋人工智慧與規則建議

採用 SHAP 標示攻擊重要特徵，對明顯攻擊特徵自動生成簡單 WAF 規則，對複雜或高度變形攻擊則提供 XAI 分析輸出，由管理者依據輸出自行設計規則。

步驟五、系統測試與驗證

模擬各類攻擊與合法流量，評估模型對未知與變形攻擊的偵測率、誤判率及規則生成效益，並與傳統 WAF 規則防護進行比較。

預期結果

本研究預期提出 AI 輔助 Web 攻擊偵測與規則建議系統，能在未知與變形攻擊的偵測上明顯優於傳統 WAF，提升準確率與召回率，並降低誤判率。同時，結合 XAI 的規則建議功能可減少管理者人工維護成本，對明顯攻擊自動生成 WAF 規則，對複雜攻擊提供決策參考，確保系統既具即時防護能力，也能支援長期安全策略的調整與優化。系統在實務測試中應能有效捕捉多種攻擊模式，並提升 Web 應用整體安全性與使用者信任度。

參考文獻

1. Bilic, I., Josic, K., Pranic, D., & Ribaric, S. (2024). WEB APPLICATION FIREWALLS (WAFS) IN PROTECTING SOFTWARE. *Annals of DAAAM & Proceedings*, 35.
2. Bakır, R. (2025). UniEmbed: A Novel Approach to Detect XSS and SQL Injection Attacks Leveraging Multiple Feature Fusion with Machine Learning Techniques. *Arabian Journal for Science and Engineering*, 1-14.
3. Zhao, Q., Liu, B., Wu, H., Zhang, Z., Hu, R., Hua, H., & Zhang, C. (2023, December). A Multi-feature Fusion Method for Web Scanning Behavior Detection in Online Web Logs. In *2023 4th International Conference on Computers and Artificial Intelligence Technology (CAIT)* (pp. 246-252). IEEE.
4. Mishra, S., & Diesner, J. (2022). PyTAIL: Interactive and Incremental Learning of NLP Models with Human in the Loop for Online Data. *arXiv preprint arXiv:2211.13786*.
5. Cate, M., & Aishat, T. (2023). Explainable AI (XAI) in Cybersecurity: Making Web Threat Detection Transparent and Trustworthy.